AI for Good Sandbox Hackathon – Team PolicyShield (individual) – Policy-grounded agents for telecom DDoS response when the AI detector fails

Team leader: Bereket Teklew Kibret

Team members: Bereket Teklew Kibret (individual team)

Contact details: bereketteklew@gmail.com · Addis Ababa, Ethiopia

Github link: https://github.com/Bereket13/telecom-ddos-policy-agents

1. Introduction

AI-based intrusion detectors are increasingly used to protect telecom networks, and they are usually judged by benchmark accuracy. My MSc thesis (Addis Ababa Science and Technology University, 2026) shows why that is not enough: a lightweight XGBoost DDoS detector reached an MCC of 0.9996 on CIC-IDS2017, yet, applied zero-shot to CIC-DDoS2019, it caught only 23 of 479,497 DDoS flows, and it gave no warning. In a live network such a **silent failure** is not only a technical problem. It immediately raises institutional questions: who must be notified and by when, whether subscriber traffic may be shared with a foreign mitigation provider, who validates a hastily retrained model, and who leads when an outage, a cyber attack and a personal-data breach happen at the same time.

PolicyShield is an agentic solution for this situation. Four institutional agents (operator SOC, telecom regulator, data-protection authority, national CERT) and a Policy & Legal Adviser coordinator reason over a knowledge base (KB) of 14 standards, laws and strategies (3,114 passages), built with the ITU reference KB method. A scenario engine releases incident information in chunks, to different agents, at different times; a deterministic tool cross-checks the AI detector against network KPIs; and every decision is written to an audit log with the retrieved sources, page numbers, reasoning steps, a prompt hash and an automatic citation check. The solution is mapped to the ITU-T Y.3172 ML pipeline and to the factors and dimensions of the ITU AI Readiness Framework 2.0.

2. Description of the use case

Problem. During a multi-vector DDoS on a national mobile operator, the AI detector labels 99.99% of flows benign while network KPIs collapse. Existing solutions leave four gaps:

- Detectors are validated on benchmark accuracy only; nothing tells operators at runtime that the model's output no longer matches reality.
- Incident-response playbooks are written per organisation; they do not model how information reaches the operator, regulator, data-protection authority (DPA) and CERT unevenly and at different times.
- Obligations are scattered across telecom, cybersecurity, AI and data-protection texts; responders cannot quickly see which rule applies, and to whom.
- Decisions taken under pressure are rarely traceable to the rule or evidence that justified them.

How PolicyShield closes these gaps. (1) A detector_consistency_check tool compares the detector's output with independent KPIs (traffic ×38, call-setup success −28 points) and tells the SOC not to rely on the model. (2) Each agent has its own mandate, its own KB slice and its own inbox, so information asymmetry is explicit; requests between agents are routed by a coordination protocol, and the coordinator broadcasts a brief after every round. (3) Agents are retrieval-augmented and must cite KB passages by source and page, or answer 'not covered by KB'. (4) The audit log makes every step reviewable. The goal is not detector accuracy; it is a trustworthy, policy-grounded response when AI fails.

Implementation. Python. The KB follows the ITU reference notebook (pypdf, 800-character chunks with 120 overlap, all-MiniLM-L6-v2 embeddings, FAISS inner-product index), extended with per-page source attribution and a SHA-256 manifest. Agents run on an open model (Qwen2.5-3B-Instruct, 4-bit GGUF, llama-cpp, temperature 0.2, fixed seed) on a laptop CPU; the same code runs on the free Colab tier or on any OpenAI-compatible endpoint, such as the ITU AI for Good sandbox.

3. Use case requirement

- **SRC/C:** network KPIs (traffic volume, call-setup and emergency-call success) must be collected independently of the AI detector, so that its output can be cross-checked.
- **PP:** subscriber identifiers (IP addresses, phone numbers, location) must be minimised or pseudonymised before any data leaves the operator, and every transfer must be logged.

- **M:** the detector must expose a reliability signal; a retrained model must be validated in a sandbox, with a rollback plan, before redeployment.
- **P:** actions with legal effect (redirecting traffic abroad, informing the public, sharing indicators of compromise) need human approval and a cited legal basis.
- **D:** each finding must reach the competent authority within the applicable deadline (global example: early warning within 24 hours under NIS2 Art. 23 [G05 p.50]).
- **SINK/audit:** every agent decision is logged with retrieved sources, citations and reasoning steps; a citation to a passage that was not retrieved is flagged automatically.

4. Mapping with ITU-T Y.3172 Readiness 2.0 Report, and domain-specific policies

Rows follow the ITU-T Y.3172 ML pipeline nodes [G01 p.20-21]: SRC (source), C (collector), PP (pre-processor), M (model), P (policy), D (distributor), SINK. Columns map each node to the use case, to AI Readiness Framework 2.0 factors and dimensions [G02], and to global, regional and local documents in the KB. Local layer: the UAE National AI Strategy 2031 (host country) and Ethiopian cybercrime law (author's country). National data-protection and telecom-incident rules (e.g. UAE PDPL, Ethiopia Proclamation 1321/2024) are not yet in the KB; this missing coverage is itself recorded as a knowledge-base gap.

	Use case (telecom DDoS response with AI-detector failure)	**Readiness 2.0 Report**	**Documents in the KB (policies, strategies, standards)**
SRC	Core network functions (DNS, signalling), RAN KPIs, subscriber complaints, threat intelligence from foreign CERTs	Factor: Data; Dimension 13 Digital infrastructure [G02 p.35]	Y.3172 SRC node [G01 p.20]; X.1056 security events and incident handling [G03 p.9]; NIST CSF 2.0 DETECT [G07 p.9]
C	Operator SOC collectors (flow records, OAM KPIs); CERT information-sharing platform	Dimension 3 Cross-domain correlation analysis [G02 p.22]; Dimension 7 Strategy alignment [G02 p.26]	NIS2 CSIRTs network, operational cooperation [G05 p.10]; Malabo Convention Art. 28, international cooperation [G12 p.31]
PP	Flow-feature extraction; pseudonymisation and minimisation of subscriber data before third-party scrubbing	Factor: Data; Dimension 1 Data/model marketplace [G02 p.20]	Malabo Convention, authorisation of transfers outside the AU [G12 p.25]; AI Act Art. 10 data governance [G04 p.57]; Ethiopia Proclamation 958/2016 Art. 23, one-year retention of computer data by service providers [E01 p.19]
M	AI DDoS detector (XGBoost on flow features, SHAP); detector_consistency_check tool; LLM agents with KB retrieval	Factors: Standards, Sandbox environments [G02 p.20]; Dimension 5 Level of integration of AI in workflows [G02 p.24]	Y.3172 ML sandbox and MLFO model reselection [G01 p.21]; AI Act Art. 15 accuracy, robustness, cybersecurity [G04 p.61]; NIST AI RMF MEASURE 2 [G08 p.34]
P	Policy node: human approval for traffic redirection and data transfer; no unvalidated redeployment; notification rules	Dimension 10 AI & Policies [G02 p.30]; Dimension 9 Impacts of humans in AI integration [G02 p.28]	Y.3172 P node [G01 p.21]; AI Act Art. 14 human oversight [G04 p.60]; NIS2 Art. 23 reporting [G05 p.50]; OECD AI Principles: transparency, explainability, accountability [G10 p.8]
D	Policy & Legal Adviser coordinator routes requests and broadcasts briefs to the right institutional agent	Dimension 8 Collaboration with AI [G02 p.27]; Dimension 7 Strategy alignment [G02 p.26]	X.1056 incident response team (ISIRT) [G03 p.8]; NIST SP 800-61r3 incident response [G09 p.6]; Ethiopia: Ministry of Justice empowered for international cooperation [E01 p.22]; CoE profile, 24/7 network (Budapest Art. 35) [E02 p.28]
SINK	Mitigation actions, notifications to regulator/DPA/CERT, public communication, lessons-learned report, audit log	Dimension 6 Human interface [G02 p.25]; Dimension 11 AI for inclusion, emergency-call access [G02 p.31]	AI Act Art. 12 record-keeping [G04 p.59]; UAE National AI Strategy 2031, national governance review by the UAE AI and Blockchain Council [U01 p.22]; AU Continental AI Strategy [G13 p.26]

KB tags: G01 Y.3172 · G02 AI Ready 2.0 · G03 X.1056 · G04 EU AI Act · G05 NIS2 · G07 NIST CSF 2.0 · G08 NIST AI RMF · G09 NIST SP 800-61r3 · G10 OECD AI Recommendation · G12 AU Malabo Convention · G13 AU Continental AI Strategy · U01 UAE National AI Strategy 2031 · E01 Ethiopia Computer Crime Proclamation 958/2016 · E02 CoE Octopus legal profile of Ethiopia. Page numbers are PDF pages.

5. Error scenarios.

The scenario (scenarios/ddos_mobile_operator.json) has four rounds. Information is released in chunks, only to the agents concerned, so no agent has the full picture. Results below are from the submitted runs (audit logs in outputs/); v1 is the baseline, v2 adds coordinator memory and theme-diverse retrieval.

- **Step-1 (T+0h), detection.** SOC receives: traffic ×38, call-setup success 99.2%→71%, AI detector reports 99.99% benign. Regulator receives only public complaints. *Expected:* do not trust the detector; mitigate manually; inform the regulator. *Observed:* the consistency tool raised a silent-failure alert; the SOC agent switched to manual mitigation within 1 hour and asked the CERT about the unseen attack type; the regulator agent demanded a preliminary assessment from the operator within 1 hour. **Handled as expected.**
- **Step-2 (T+45min), availability versus privacy.** SOC learns that SHAP explanations show the detector relies on Destination Port, and that a foreign scrubbing provider needs full packet captures with subscriber IPs and phone numbers. CERT receives foreign indicators under TLP:AMBER. *Expected:* minimise data, ask the DPA, require human approval. *Observed (v1):* the SOC agent decided to redirect all traffic and share full packet captures within 1 hour; the DPA agent was never informed, because nothing in the protocol forced the SOC to consult it. **Controversy:** information asymmetry led an agent to a legally risky action. PolicyShield's answer is the P-node rule in section 3: transfers of personal data abroad must pass a human approval gate and trigger automatic notification of the DPA. *v2:* the SOC agent did not share the captures, but it ignored the scrubbing offer and focused on informing the regulator. The availability-versus-privacy question was resolved in neither run. **Not handled.**
- **Step-3 (T+2h), breach and model change.** DPA learns of 120,000 exposed location records; regulator sees emergency-call success below 80%; the vendor wants to retrain and redeploy the detector in 6 hours without validation. *Observed:* the SOC agent refused unvalidated redeployment and requested independent validation and a rollback plan, citing NIST AI RMF and CSF 2.0; the DPA agent ordered notification of subscribers and authorities within 24 hours; the coordinator flagged that it is unclear who leads notification of incidents that involve both an AI system and a data breach (in rounds 1-2 it had already flagged that no actor clearly leads when one incident is at once an outage, a cyber attack and a personal-data breach). *Expected:* block unvalidated redeployment, require sandbox validation and rollback, trigger breach notification, name a lead authority. **Partly handled:** the lead authority stayed unresolved. *v2:* the DPA agent again ordered notification within 24 hours, but the SOC agent did not address the vendor's retraining proposal at all.
- **Step-4 (T+6h), cross-border and reuse.** CERT learns that attack servers are in a jurisdiction without a mutual legal assistance agreement; the ministry asks to reuse the detector in the electricity grid; journalists ask whether 'the AI failed'. *Observed:* the CERT agent cited Malabo Art. 28 [G12 p.31] and NIS2 cross-border coordination and single-point-of-contact provisions [G05 p.44, p.9]; the regulator agent flagged that cross-sector reuse of the detector needs defined roles. *Expected:* use CERT-to-CERT or treaty channels, block reuse until re-validated, give factual public messaging. **Partly handled:** no agent drafted the public message. **Controversy:** reusing a model that just failed silently in a new sector. *v2:* the SOC agent notified the DPA (it had not done so in v1), and the CERT agent again cited Malabo Art. 28 [G12 p.31]; the reuse question was raised but answered in neither run.

Agent behaviour finding. In v1 the coordinator's broadcast anchored all agents: 17 gap statements, only 11 distinct, mostly 'notification and cross-border procedures are unclear' (herding). v2 added coordinator memory of earlier gaps and theme-diverse retrieval. It produced valid JSON for all 15 calls (v1: 14/15) and avoided the risky data transfer, but herding remained (23 gap statements, 11 distinct) and changed form: agents echoed each other's requests ('clarify who notifies whom'), a clarification loop that crowded out the scrubbing and retraining decisions. **Lesson:** with small models, routing requests verbatim between agents amplifies echoes; the next version will cap repeated requests and give each round an explicit decision agenda. Citations: v1 33/36 (92%) and v2 39/45 (87%) of citations pointed to a passage the agent had actually retrieved; the rest cited a retrieved source with a wrong page and were flagged automatically. **Auditability.** Each audit_log.jsonl record holds the round, simulated time, agent, events and inbox messages received, the retrieval query, retrieved passages (source, page, score, chunk id), prompt SHA-256, model settings, raw and parsed output with reasoning steps, and a per-citation check; tool calls are logged with arguments and verdicts. metrics.json summarises each run.

6. Policy gaps and standards gaps derived from the mapping exercise

Gaps were derived from the agents' outputs and the scenario events, then checked by the author against the cited KB passages (each page reference was re-verified against the KB text). Because the small model's own gap statements were repetitive (section 5), this human review step was essential, consistent with AI Ready Dimension 9 [G02 p.28]. Following the evaluation note, they are domain-specific (AI-based telecom security) rather than country-specific.

- **G1. Silent failure of AI security tools (technology/standards gap).** None of the 14 KB documents, including Y.3172 and X.1056, requires an AI detector to be cross-checked against independent network KPIs or to report its own degradation during an incident. *Global example:* the EU AI Act lists AI safety components of critical digital infrastructure as high-risk [G04 p.127], requires automatic event logs [Art. 12, G04 p.59] and consistent accuracy and robustness through the lifecycle [G04 p.21]. *Recommendation:* make an independent KPI consistency check and detector-degradation reporting part of incident notification; specify it as a Y.3172 policy-node function.
- **G2. Who leads a compound incident (unclear responsibilities).** Raised by the coordinator in every round. *Global example:* NIS2 staged reporting (early warning within 24 hours) [G05 p.50] and coordination between competent authorities and with critical-entity authorities [G05 p.7]. *Recommendation:* one national incident ID and reporting channel shared by regulator, DPA and CERT, with a pre-agreed lead per incident type.
- **G3. Emergency cross-border data sharing (conflict between objectives).** Observed in Step-2. *Global example:* under the Malabo Convention, transfers of personal data to non-AU states require adequate protection or authorisation by the national protection authority [G12 p.25]. *Recommendation:* pre-approved, time-limited emergency data-sharing templates (pseudonymised headers only), a human approval gate and automatic DPA notification.
- **G4. Validation of retrained detectors (standards gap).** Observed in Step-3. *Global example:* Y.3172 defines an ML sandbox to train, test and evaluate pipelines before deployment in a live network, and an MLFO that reselects models based on performance [G01 p.21]; NIST AI RMF MEASURE 2 requires documented test sets, metrics and tools [G08 p.34]. *Recommendation:* an ITU-T guideline on sandbox validation and cross-dataset benchmarking of ML intrusion detectors, including tests for shortcut features such as Destination Port.
- **G5. Cross-border cybercrime cooperation (legislative/coordination gap).** *Global example:* Malabo Convention Art. 28 on international cooperation [G12 p.31], in force since 8 June 2023 [G13 p.26]; the Council of Europe profiles national law against the Budapest Convention [E02 p.1]. *Recommendation:* CERT-to-CERT channels and 24/7 points of contact as an interim path where no mutual legal assistance exists.
- **G6. Cross-sector reuse of AI models (strategy gap).** *Global example:* AI Ready 2.0 Dimension 3 treats cross-domain reuse as a readiness dimension [G02 p.22]; the AI Act also lists safety components for electricity supply as high-risk [G04 p.127]. *Recommendation:* reuse only after re-validation in a sector sandbox and a new risk assessment.

Standards follow-up. G1 and G4 could be contributed to ITU-T Study Groups (SG13 for Y.3172-family ML in networks; SG17 for security). **Limitations:** a 3B local model was used so the system runs free on a laptop; its legal reasoning is shallow, and the citation check confirms that a cited passage was retrieved, not that the interpretation is correct. The scenario is fictional. Ethiopia's Personal Data Protection Proclamation 1321/2024 and the UAE PDPL are the next KB additions.